

**Type of Policy:** Administrative

**Effective Date:** January 2017

**Last Revised:** January 2017

**Review Date:** April 2025

**Next Review Date:** April 2027

**Policy Owner:** ACME Corporation CyberSecurity

**Contact Name:** John Kaset

**Contact Title:** Governance Risk & Compliance Manager

**Contact Email:** johnkaset@acmecorp.com

**Reason for Policy**

The ACME Corporation Data Privacy Policy provides the standards the Corporation follows when accessing the files and communications of its employees and contractors. In the interest of promoting corporate efficiency and the mission of the Corporation, ACME Corporation recognizes its obligation not to infringe upon the reasonable privacy expectations of its employees and contractors in their electronic communications and data.

**Policy Statement**

ACME Corporation provides information technology resources to employees and contractors to further ACME Corporation's mission and conduct ACME Corporation business. While personal use of such systems is permitted, per the ACME Corporation Acceptable Use Policy, personal communications and files transmitted over or stored on ACME Corporation systems are subject to the same regulations as business communications.

ACME Corporation is committed to respecting the privacy expectations of its employees and contractors; however, consistent with this policy, electronic information that is transmitted over or stored in ACME Corporation systems and networks is subject to being audited, inspected, and

disclosed to fulfill administrative or legal obligations which may include, but are not limited to the following:

- Compliance with legal requirements or process (e.g., subpoenas)
- Investigation of a suspected violation of law or regulations or a suspected infraction of ACME Corporation or Board of Directors policy
- Maintaining the security of ACME Corporation computing systems and networks
- Diagnosing and correcting problems with system software or hardware
- Handling emergencies
- Proceeding with ordinary business activities, such as accessing data associated with an employee who has been terminated/separated, is deceased, is on extended sick leave, or is otherwise unavailable.
- Complying with a written request from the Vice President for Human Resources on behalf of the parents, guardian, or personal representative of the estate of a deceased employee
- Conducting research authorized by ACME Corporation under a data use agreement that precludes the disclosure of personally identifiable information

### **Employee Consent Statement**

By using ACME Corporation resources, employees and contractors must acknowledge and consent to the following:

- Activities within resources must be reviewed without notice for security and compliance reasons.
- Consent accounts for internal policies such as data use, privacy, and proper system access.
- Must cooperate with investigations regarding data access, loss, or misuse.

- Continued use of IT resources affirms understanding of these terms.

### **Data Classification Reference**

All data transmitted or stored on ACME Corporation IT resources must be handled with the following:

- Data is sorted upon these levels:
  - Public
  - Internal
  - Confidential
  - Restricted
- Access and monitoring depend on the level of classification
- Employees and users are responsible for identifying and protecting sensitive data

### **Third Party and Vendor Data Handling**

Third-party vendors and service providers that need access to the ACME Corporation system or data must follow the same privacy and confidentiality required by internal employees and contractors.

- Vendors may be subject to audits and review
- Data Shared must be covered by the Data Use Agreement or Vendor Privacy Addendum
- Access is only allowed when data is needed for business operations

### **Retention and Logging Standards**

For transparency, legal compliance, and security reasons:

- Access logs, audit trails, and activity records must follow the ACME Data Retention and Logging standards
- Logs are required to be kept a 4-year minimum

- Logs may be reviewed or audited during an investigation to ensure the proper use of IT resources

## **Scope**

This policy governs access to the files and communications transmitted on or stored in ACME Corporation's IT Resources.

Any individual whose personal files and communications exist on an ACME Corporation IT Resource by unauthorized access will have no expectation of privacy.

## **Definitions**

- *Information Technology Resources (IT Resources)* – Computers, Networks, Devices, Storage, or other IT equipment.
- *Data Classification* – Organizing data based on the level of sensitivity and value.
- *Data Use Agreement* – A contract that states how sensitive data must be accessed, used, and protected.

## **Procedures**

### **Application, System, and Network Login Banner**

Where possible, all ACME Corporation applications and systems (excluding endpoints and mobile devices) must display the following login banner to all users before authentication of user credentials:

## **TERMS OF USE**

This information technology resource is the property of ACME Corporation and is available for authorized use only by corporate IT policies. Any and all files on this system are subject to being audited, inspected, and disclosed to authorized system administrators and/or law enforcement

personnel to fulfill administrative and/or legal obligations. By using this system, I acknowledge these terms.

### **Requests for Access**

All requests for access to information transmitted over or stored on ACME Corporation systems and networks should be directed to the Chief Information Officer or designee. The Chief Information Officer or designee determines whether access to information is necessary to fulfill administrative or legal obligations. It may not be made at the departmental or unit level.

### **Justification**

#### **Small Policy Updates**

Review update

- Shortening the review cycle of the policies allows for changes in a world full of new innovations and evolving technologies (ISO/IEC 27001).

#### **Employee Consent Statement (New Section)**

Added Employees must consent to monitoring, audits, and investigations when using any company's systems/equipment.

- This ensures transparency and legal defensibility throughout policies. Helps with mitigating unauthorized surveillance or breaches. Also, it lets the user know that IT resources are being used correctly (NIST SP 800-53 – AC – 8).

#### **Data Classification Reference (New Section)**

This clarifies that data oversight will be classified based on four classifications: public, internal, confidential, and restricted.

- It improves employees' understanding of their work's risk and ensures correct handling of it. Enforces access, monitoring, and retention based on sensitivity (NIST SP 800-60 Vol. 1)

#### **Third-Party and Vendor Data Handling (New Section)**

Vendors and third parties must follow the employees' similar terms in trying to keep the information confidential by using DUAs or vendor agreements.

- Addresses any issues that SaaS, cloud, and IT vendors might create in companies' security. Prevents and data exposure third parties might present and follow regulations (ISO/IEC 27018).

## **Retention and Logging Standards (New Section)**

Logs must be kept for at least 4 years and can be reviewed or looked at when an investigation occurs.

- It aligns with many frameworks, such as HIPPA and NIST, as it helps with investigating, detecting, and privacy violations. Provides an accurate timeline for data lifecycle (NIST SP 800-92).

## **Definitions Expansion**

Data Classification

- It is crucial for user context when referring to sensitive data. (NIST SP 800-60 Vol. 1).

Data Use Agreement (DUA)

- Makes sure that vendors know access control and privacy expectations and helps them use context when reading policies (ISO/IEC 27018).

## References

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53 Rev. 5).

<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

National Institute of Standards and Technology. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). <https://csrc.nist.gov/publications/detail/sp/800-92/final>

National Institute of Standards and Technology. (2003). *Guide for mapping types of information and information systems to security categories* (NIST SP 800-60 Volume 1).

<https://csrc.nist.gov/publications/detail/sp/800-60/vol-1-rev-1/final>

International Organization for Standardization. (2019). *ISO/IEC 27018:2019 – Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors*. <https://www.iso.org/standard/76559.html>

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 – Information security management systems – Requirements*. <https://www.iso.org/isoiec-27001-information-security.html>